

Module -7: Auditing basics

1. Which of the following statements are requirements from the ISO 27001 standard?

1. There should be a documented procedure for monitoring and measuring – Incorrect! ISO 27001 doesn't have such requirement. The standard requires for documented information as evidence of the monitoring and measuring results, so this is an assumption.

2. The company should have a documented Information Security Policy. – Correct! According to clause 5.2 from ISO 27001, the company should establish an Information Security Policy that will be available as documented information.

3. Top management should conduct a management review meeting regularly. – Incorrect! According to clause 9.3 from ISO 27001, the top management of the company shall conduct a review of the ISMS regularly, which can be conducted through a meeting, but through other means as well. So, this is an assumption because conducting a meeting for management review is not mandatory.

4. The company should have documented information from the risk assessment process. – Correct! According to clause 6.1.2 the company should keep documented information about the information security risk assessment.

2. Choose the most suitable approach for collecting evidence for the following situation:

The company has documented a detailed Access control policy and Password policy, and has implemented a Domain policy for passwords for the operating system and separate access control for all applications.

1. Interviewing the employees without reviewing the policies and observation of technical implementation – Incorrect! Since the ISMS is very well documented and has implemented various technical controls, first the documented information should be reviewed (the policies), and afterwards it should be observed how the technical controls are implemented, i.e., checking the implementation of the implemented access control for several applications.

2. Observation of the operations of the employees – Incorrect! Since the ISMS is very well documented and has implemented various technical controls, first the documented information should be reviewed (the policies), and afterwards it should be observed how the technical controls are implemented, i.e., checking the implementation of the implemented access control for several applications.

3. Reviewing the policies and observing the implemented technical controls – Correct! After the auditor finds out what needs to be done, he/she must check if the implementation of the technical controls is compliant with the written rules.

3. Choose the most suitable criteria for sampling the corresponding records for the following situation:

Company ABC has 40 employees, and has had an ISMS that is certified for over 7 years. The ISMS is technically sophisticated, i.e., supported by extensive technical and automated controls such as intrusion detection systems, automated backup system, domain-controlled IT infrastructure, etc.

The Backup policy states that the backup is being automatically performed once a day, in the morning. In the event you need to review the records for the last 6 months to prove that the backup has been conducted as planned, how many backup logs will you be looking to check?

3-5 – Correct! Since the backup is an automated control, the possibility for error is minimal. If the system is set to perform the action once a day, it will perform it once a day. So, checking 3-5 logs to see if the system is really functioning as set up is enough.

40 – Incorrect!

180 – Incorrect!

4. From the following list of examples of interviewing techniques, choose all the examples that represent a good practice and positive approach:

1. Ensuring questions are clear and understood. Avoiding jargon, using plain and simple language. – Correct!

2. Always asking questions that can be answered with yes or no. – Incorrect! During the audit, you should ask questions that will allow the auditee to engage in a conversation with you, and explain what they do and how, so examples for good questions are how, what, why... questions. Questions that can be answered with yes or no should be avoided when possible.

3. Asking a lot of questions that will help you find out the root cause of the problem – Correct!

4. Asking a lot of questions in a row, and by that, giving a chance to the auditee to choose which question they want to answer – Incorrect! The auditor should ask one question at a time and leave the auditee time to answer that question.

5. 60% of the time the auditor should spend asking questions, and 40% of the time should be for the auditee to answer questions – Incorrect! The ratio should be 30% of the time for auditor's questions, and 70% for getting the answers.

5. Which of the following statements are nonconformities:

1. The anti-virus definition on a few computers is not up to date. – Correct!

2. The procedure for internal audit can be improved by adding an audit plan. – Incorrect! This is an observation because audit plan is not a requirement.

3. The company does not have an Information Security Policy. – Correct!

4. The anti-virus definition on the extra laptop used as backup when some of the laptops are taken for repair is not up to date. This is an isolated case, but should be noted to avoid possible problems in the future. – Incorrect! This is an observation because this case does not influence the security of information or functioning of the ISMS.

6. Choose all the statements from the list that represent a nonconformity.

1. The procedure for backup states that backup of the file server and mail server is performed on a daily basis; however, the backup jobs and logs show that daily backups are performed only on the file server, while the mail server has weekly backups. – Correct!

2. Based on the procedure for internal audit, the audit is performed once a year; however, because of the rapid increase in new employees in the last year the internal audit was conducted twice a year in order to achieve better results and raise awareness of the new employees. – Incorrect! The

minimum of one audit per year as prescribed by the procedure was performed. The second audit was in order to achieve better results.

3 Management review was not conducted for 3 years in a row. – Correct!

4. The Information Security Policy is documented and signed by the Managing Director, but the policy is kept in the folder of the Information security officer and is not communicated throughout the organization. – Correct!

5. The policy for e-commerce services does not exist. – Incorrect! The standard does not require an e-commerce policy.

7. Choose all the statements from the list that represent an observation:

1. An Information Security Policy does not exist. – Incorrect! This is a nonconformity; the Information Security Policy is a mandatory requirement of the ISO 27001 standard.

2. Based on the procedure for internal audit, the audit is performed once a year; however, because of the rapid increase of new employees for the next period the internal audit should be conducted twice a year in order to achieve better results and raise awareness of the new employees. – Correct!

3. The Access Control Policy is documented, but is not implemented in practice. – Incorrect! This is a nonconformity because although there is a document, the control is not implemented, which means that there is inconsistency between the documentation and practice and possibly no adequate access control.

4. The capacity management control can be enhanced by introducing open source software for monitoring the capacities and actual performance of the system. – Correct!

8. What type of audit of your ISMS would be performed by a potential partner? The purpose of the audit is for your potential partner to evaluate the effectiveness of your ISMS before signing a partnership agreement with your company for a project that processes very sensitive information.

1. Internal audit – Incorrect! The internal audit is conducted for internal purposes and is used only internally; this audit is performed for the need of the potential partner.

2. External audit – Correct!

9. Company XYZ has had a certified ISMS based on ISO 27001 for 9 years. The company has 50 employees, 4 departments (sales, procurement, production, and customer care) and is located on two sites in different cities 500km apart (the administrative offices and the production facilities).

Having in mind the relevant elements of an audit program – scope, audit criteria, audit methods, number of auditors – what would be the optimal number of audits performed during a one-year period?

1. 1 audit – Incorrect! – More resources will be required if the internal audit of the entire ISMS is conducted as one audit. Either 2 auditors will need to be engaged at the same time and they would need to spend time coordinating themselves, or if one auditor conducts the audit she/he will need to travel to the second location 500km away, etc. Although, the internal audit could be realized within one audit (especially having in mind that the ISMS has been maintained for 9 years), the optimal number of internal audits would be two, one audit per location.

2. 2 audits – Correct! Two would be the optimal number of internal audits, one per location. Having in mind that the ISMS has been maintained for 9 years in the organization and is regularly audited externally, the audit is established practice and should go smoothly. In order to utilize resources more effectively (avoid traveling between the two sites 500km apart, thus saving time and money), two internal auditors should organize and conduct the audits separately. They will both prepare separate audit reports.

3. 3 audits – Incorrect! Having in mind that the ISMS has been maintained for 9 years in the organization and is regularly audited externally, the audit is established practice and should go smoothly. Therefore, there is no need to conduct more than one audit per location, two audits in total.

4. 4 audits – Incorrect! Having in mind that the ISMS has been maintained for 9 years in the organization and is regularly audited externally, the audit is established practice and should go smoothly. Therefore, there is no need to conduct more than one audit per location, two audits in total. Having 4 audits would be utilizing more resources (time and money) than needed.

10. Which of the following elements should be included in the audit plan:

1. Sales process will be audited. – Correct!

2. The lead auditor is responsible for organizing the internal audit and coordinating the internal auditors. – Incorrect! This is a description of the responsibilities of the lead auditor, which should be included in the internal audit procedure; it should not be part of the audit plan.

3. The managing director will be audited for the relationship with the supplier's process. – Correct!

4. The auditing of the sales department will be realized by Auditor no. 1. – Correct!

5. The audit is scheduled for Monday, June 16, 2015, 10:00-11:00 am. – Correct!

6. All internal auditors should be familiar with the requirements of the ISO 27001 standard – Incorrect! This is a criterion for choosing an internal auditor; it should not be part of the audit plan.

11. Company XYZ has had a certified ISMS based on ISO 27001 for 9 years. The company has 50 employees, 4 departments (sales, procurement, production, and customer care) and is located on two sites in different cities 500km apart (location 1: the administrative offices and location 2: the production facilities). Only 5 people are situated in the administrative offices (location 1), among which is one IT administrator responsible for the IT infrastructure there.

Prepare a checklist for internal audit in the administrative offices (location 1), by filling in the second column for the following 3 clauses of the ISO 27001 standard. The second column should be filled in by choosing the most appropriate items provided below the checklist.

1. 5.2 Policy - Check if the most updated version of the IS Policy is uploaded to the company DMS (Document Management System).

2. A.15.2.1 - Review the supplier evaluation sheets.

3. A.8.3.2 - Check how media are disposed of in practice by interviewing all the 5 employees on that topic.

12. Which of the following elements could be included in the internal audit report?

1. The internal audit was conducted on May 14, 2015, by Auditor X. – Correct! This is basic information about the date of the audit and which auditor conducted the audit.

2. The internal audit should be conducted twice a year. – Incorrect! This statement is part of an internal audit procedure; it sets the rules of the frequency of the internal audit.

3. Will be two internal audits performed in 2015, one at the beginning of the year, and the second in September. – Incorrect! This statement can be a part of an internal audit program; it shows the frequency and scheduling for the internal audits in 2015.

4. Nonconformity number 3 – “The backup wasn’t tested in the last year and a half, although the backup policy states that the backup will be tested at least twice a year.” – Correct! This is a description of the nonconformity that was identified during the audit.

13. How much time would be optimal to leave for implementation of the following corrective actions before conducting a follow-up?

Corrective action 1 – Update the backup policy document to be aligned with the backup practice, which has proven to be very effective:

1. 1 week – Incorrect! Advantage: The corrective action will be closed quickly. (Since only concrete changes in the document are required, the changes can be implemented very easily and quickly.) Disadvantage: Putting too much pressure on the person who needs to implement the corrective action, i.e., update the policy. Also, such a short timeframe might contribute to perceiving the action as an urgent matter, while there might be higher-priority issues.

2. 1 month – Correct! Advantage: The corrective action will be closed relatively quickly, while at the same time there will be opportunity to deal with more critical matters. Since only concrete changes in the document are required, the changes can be implemented very easily and quickly. However, because appropriate backup practice is already implemented, and the nonconformity is related to the documentation, this corrective action might have lower priority compared to corrective actions that tackle more high-risk areas and/or lack of controls. Disadvantage: /

3. 6 months – Incorrect! Advantage: / Disadvantage: Extending the things that can be finished easy and quickly for too long, thus losing focus and decreasing the overall effectiveness of the ISMS.

14. Define what kind of evidence is each of the following:

1. Observation - The server room (second floor no. 26) is equipped according to the best practices, air conditioned to 23° C, the air conditioner is positioned on the opposite side of the racks, the floors are raised, etc.

2. Record - Backup log no. 2268, June 31, 2014

3. Interview - John Smith, IT administrator, September 7, 2015, 15:30, “The backup is tested every month, no log is kept as evidence.”

4. Document - Control of documented information procedure v4, April 20, 2012

15. The following outcomes represent audit findings:

1. Issue – Incorrect! Audit findings are nonconformities and observations. Issue does not exist as a concept in ISO 27001.

2. Major nonconformity – Correct!

3. Observation – Correct!

4. Incident – Incorrect! Audit findings are nonconformities and observations. Incidents happen separately from the audit.

5. Problem – Incorrect! Audit findings are nonconformities and observations. Problem does not exist as a concept in ISO 27001.

6. Minor nonconformity – Correct!

16. A nonconformity is considered to be a major one if it satisfies at least one of the following criteria:

1. A requirement hasn't been fulfilled at all. – Correct!

2. A requirement is only partially fulfilled. – Incorrect! This is a case of a minor nonconformity.

3. An ISMS process has completely broken down. – Correct!

4. A minor nonconformity has not been resolved within the deadline. – Correct!

5. There are several minor nonconformities related to the same ISMS element. – Correct!

6. There are several observations related to the same ISMS element. – Incorrect! Observations cannot lead to a major nonconformity.

17. An observation can be positive or negative.

1. True – Correct!

2. False – Incorrect! Nonconformities can be minor or major, and observations can be positive (possibility for improvement or positive examples) and negative (isolated case of not following the company policies).

18. The audit program should define activities during an individual audit.

1. True – Incorrect! The audit program should define a series of individual audits, while defining activities during an individual audit is done through the audit plan.

2. False – Correct!

19. The information to be included in the internal audit checklist should be the following:

1. Description of the requirement and clause/number of the document where this requirement was mentioned – Correct! This information is entered during the audit.

2. Record whether the company is compliant with the requirement or not – Correct! This information is entered during the audit.

3. Notes – Correct! During the audit, the internal auditor will need place to write detailed notes.

4. Steps in the audit – Incorrect! These steps are to be included in the Audit plan.

20. The auditor doesn't need to know where the records are located – he has to ask an auditee to present them.

1. True – Correct.

2. False – Incorrect. The auditor needs to know which records are important for an ISMS, and the auditee will need to know where those records are located.

21. Why is observation of activities and facilities important as an audit technique?

1. Because this is sometimes the only way to check if the company is compliant with its own procedures, and if things are running as the employees are claiming – Correct!

2. Because ISO 27001 requires an auditor to check all the facilities and activities – Incorrect! ISO 27001 has no such requirements.

3. Because this is the best way for the internal auditor to suggest improvements on the spot – Incorrect! Although these suggestions might be valuable, the auditor's main job is finding evidence.

22. In most cases, open-ended questions are better than closed-end questions.

1. True – Correct!

2. False – Incorrect! Open-ended questions stimulate the auditee to provide much more information.

Module -8 Understanding auditing standards

23. A business can become accredited to ISO 9001 if it is required by their suppliers.

1. True – incorrect.

2. False – correct. A business can become certified to ISO 9001, but their certification body must be accredited.

24. The correct order for the formally required certification audit process is:

1. Stage 1, stage 2, gap analysis, recertification audit – incorrect. Gap analysis is not a formal requirement of the certification process.

2. Gap analysis, stage 1, stage 2, recertification audit – incorrect. Gap analysis is not a formal requirement of the certification process.

3. Stage 1, stage 2, surveillance audits, recertification audit – correct.

4. Gap analysis, Stage 1, stage 2, surveillance audits, recertification audit – incorrect. Gap analysis is not a formal requirement of the certification process.

25. Certification to more than one management system standard can be achieved through an integrated audit:

1. True – correct.

2. False – incorrect. More than one management system can be audited at the same time in an integrated audit.

26. An organization with ISO 9001 certification will need to:

1. Comply with the requirements of ISO 17021-1 – incorrect. This standard is for the certification body to follow.

2. Comply with the requirements of ISO 19011 – incorrect. This standard is guidance and not a requirement.

3. Comply with the internal audit requirements of ISO 9001 – correct. The organization needs to comply with these requirements to maintain certification.

27. Lead certification auditors must:

1. Meet the certification body's competency requirements – correct.

2. Have an externally recognized auditing qualification – incorrect. Externally recognized qualifications do not define competency for certification auditors.

3. Have a minimum number of years' experience in the industry sector that they will be working in – incorrect. This does not demonstrate competency for certification auditors.

28. IAF mandatory documents need to be applied for internal audit processes so that the organization's certified management system standard is recognized internationally.

1. True – incorrect. IAF MDs are mandatory for accreditation bodies, and set the expectations for certification bodies, but are not requirements for internal audits.

2. False – correct.

29. ISO 19011 is a mandatory standard that organization who undertake internal audits must use.

1. True – incorrect. The use of the standard is voluntary! It is a guidance document only.

2. False – correct.

30. Following the auditing principles is important, so that:

1. An effective and meaningful audit is delivered – correct.

2. Auditors do not feel pressured into raising non-conformities – incorrect. Auditors should raise non-conformities whenever they exist.

3. Clients are kept content and continue to use them in the future – incorrect. Although this might happen if the auditor conducts effective audits, it is not the reason to follow auditing principles.

31. Certification against an ISO management system standard is available to any organization; however, accreditation to ISO 17021-1 is only required for certification bodies that want to issue certificates.

1. True – correct.

2. False – incorrect. Any organization can apply for certification to an ISO management system standard, but only certification bodies follow ISO 17021-1.

32. All the competency requirements for a lead auditor are contained in the ISO 17021-1 document.

1. True – incorrect. Additional technical competency requirements are contained in other ISO 17021 documents, for example ISO 17021-3 for lead auditors in Quality Management Systems.

2. False – correct.

33. Auditors should apply the principles of auditing at all times during audits.

1. True – correct.

2. False – incorrect. It is essential for the validity and meaningfulness of certification audits that auditors demonstrate the right personal characteristics and principles.

Module 9 - Understanding audit roles and responsibilities

34. The Lead Auditor is a representative of:

1. The audit client – incorrect.

2. The accreditation body – incorrect.

3. The certification body – correct. The Lead Auditor acts on behalf of the certification body.

35. The activities that an auditor is required to perform during an audit are captured in the audit plan.

1. True – correct.

2. False – incorrect. The audit plan will indicate what activities each auditor is to perform

36. A technical specialist is part of an audit team even if they are not a competent auditor.

1. True – correct. The role of technical specialist is separate from the role of auditor, and anyone who is performing the role needs not be a competent auditor.

2. False – incorrect.

37. The audit client is:

1. The person who requests the audit to be carried out – correct.

2. The person who is responsible for making payment for the audit – incorrect. This can be someone else within the business.

3. The person from the certification body who manages the contract – incorrect. The certification body is not the audit client.

38. Management is responsible for ensuring their staff are aware of the audit and understand the need to be involved in audit activities if requested.

1. True – correct. This is a responsibility for management to make sure the audit is effective.

2. False – incorrect.

39. The responsibility of the auditee is to:

1. Put together the audit plan for the audit – incorrect. This is done by the lead auditor.

2. Agree to the audit scope and criteria – incorrect. This is done by the lead auditor and audit client.

3. Ensure the on-site arrangements are in place for the audit to take place – correct.

40. Which is not a role of the host:

1. Escort and guide the auditors on the site, and introduce them to the interviewees – incorrect. The host would do this.

2. Co-ordinate the gathering of audit evidence requested by the auditors – incorrect. The host would do this.

3. Provide answers for interviewees when they don't know the answers – correct. It is inappropriate for the host to provide answers for interviewees.

41. If there is only one auditor carrying out the audit, this auditor will perform the duties of the lead auditor and auditor.

1. True – correct. For solo audits, the one person is the lead auditor and must be competent as a lead auditor, and will also conduct the auditor role.

2. False – incorrect.

42. It is the lead auditor who makes the final decision about whether or not to issue a certificate to an audit client.

1. True – incorrect.

2. False – correct. It is the certification reviewer who makes the final decision, using evidence provided by the lead auditor. The lead auditor makes a recommendation.

43. Management do not need to be involved in the audit if they are too busy.

1. True – incorrect.

2. False – correct. Although it may not be necessary for all managers to be involved, it is essential that the necessary managers are involved in the audit, in order to engage with the auditor. This is, after all, a **management** systems audit!

Module 10 - Planning the audits

44. The audit objectives are written by:

1. The audit client – incorrect. They do not write the audit objectives.

2. The certification body – correct. The certification body will define the audit objectives.

3. The lead auditor – incorrect. The lead auditor works according to the objectives set by the certification body.

45. The locations where the audit will be carried out are contained in the:

1. Audit objectives – incorrect. This defines why you are doing the audit, and what the purpose of the audit is for the organisation.

2. Audit scope – correct. The scope defines what is being audited, what processes or parts of the organisation, and where the audit will take place.

3. Audit criteria – incorrect. This defines the standard you will be testing the organisation against.

46. When planning audits, it is best to:

1. Prioritise document review processes, because all the information about the management system will be written here – incorrect.

2. Use a mix of audit methods, depending on the audit objectives, scope, and criteria – correct. Yes, you should choose the audit methods that are going to best gather the audit evidence you need according to the objectives, scope, and criteria.

3. Have an equal balance of document review and management interviews – incorrect. It would depend on the audit scope and the organisation being audited as to what the best balance is.

4. Use a mix of audit methods to best match the competency of the auditors on the audit team – incorrect. The audit team should be selected based on the audit plan and methods, not the other way around.

47. A good sample rate for audit evidence is:

1. 10% of all evidence – incorrect. There is no set number.

2. 100% of all evidence – incorrect. There is no set number.

3. Something to agree on with auditors in advance, depending on the audit scope and criteria, and the defined audit plan – correct.

48. Remote auditing techniques include off-site document review and data evaluation, use of video- and teleconferencing, emails, and instant messaging.

1. **True – correct.** These are all types of remote auditing techniques.

2. **False – incorrect.**

49. Remote auditing techniques are:

1. **Applicable to financial and IT audits only – incorrect.** Remote auditing can be used for any type of management systems audit.

2. **Can be used on any audit where the audit client specifies it should be used – incorrect.** This may not be the best choice of audit methods to meet the audit objectives.

3. **Can be used when it helps meet the audit objectives, scope, and criteria, depending on the audit evidence that needs to be gathered – correct.**

4. **Can be used when it helps gather audit evidence that would not be available during on-site auditing activities – incorrect.** It would depend on whether this evidence is needed to meet the audit objectives, scope, and criteria.

50. Remote auditing techniques do not need to be part of the audit plan if they take place outside the times that on-site auditing activities take place.

1. **True – incorrect.**

2. **False – correct.** The use of remote auditing should be included in the audit plan, even if it is conducted outside the times of the on-site audit activities.

51. Audit team competency is based on:

1. **Knowledge and experience of the organisation's operations – incorrect.**

2. **Auditing skills, knowledge, and experience – incorrect.**

3. **Knowledge and understanding of the audit criteria – incorrect.**

4. **The right personal qualities and behaviour – incorrect.**

5. **All of the above – correct.**

52. Select a correct statement:

1. **The lead auditor is responsible for the safety of auditors when conducting audits on-site – incorrect.**

2. **The auditee is responsible for the safety of auditors when conducting audits on-site – incorrect.**

3. **Auditors are responsible for their own safety when conducting audits on-site – incorrect.**

4. **Lead auditors, auditors, and auditees are all responsible for the safety of auditors conducting audits on-site – correct.** All three parties have a role in ensuring the safety of auditors on-site.

53. The audit plan should be approved by the auditee.

1. True – incorrect. The lead auditor develops the audit plan to meet the audit objectives, scope, criteria, and methods. The auditee should confirm whether the audit plan is achievable or whether something could prevent it from being followed.

2. False – correct. The auditee does not approve the audit plan.

54. Once developed and agreed on with the auditee, the audit plan should never be changed.

1. True – incorrect. The audit plan may well change during the course of the audit, or even before the audit if circumstances change. The plan needs to be dynamic to account for changes in risks or conditions that could affect the audit objectives being met.

2. False – correct.

55. The audit client does not need to be contacted before the audit if you have been to the site before and are familiar with it.

1. True – incorrect. Contact should be made for all audits to confirm the audit plan is achievable.

2. False – correct.

56. Audit team members are responsible for ensuring they have the correct equipment and tools for their roles.

1. True – incorrect.

2. False – correct. Although you would expect this from a competent auditor, as lead auditor you need to confirm that this is actually the case.

57. What three aspects of the audit need to be defined before you can plan the audit?

1. Cost, scope, and criteria – incorrect. Cost is not essential to plan the audit!

2. Scope, criteria, and objectives – correct.

3. Audit team, dates, and logistics – incorrect. These things need to be planned, but based on the scope, criteria, and objectives.

4. Number of audit days, dates, and audit risks – incorrect. These also need to be planned, but based on the scope criteria and objectives of the audit.

58. Sampling just a limited few records to audit is lazy and should not be encouraged.

1. True – incorrect.

2. False – correct. Sampling of records during an audit is appropriate, ideally using a predefined sampling protocol, or you agree that the auditor can decide how many records are appropriate to audit.

59. In a well-planned audit, the lead auditor makes contact with the audit team and the audit client to discuss the audit plans.

1. **True – correct.** It is better to discuss the audit with both the audit team and audit client in advance of the audit, to make sure everything is well planned before you arrive on site.

2. **False – incorrect.**

Module 11 - Managing the audit process

60. The opening meeting is a good opportunity to interview the management team, seeing as they are all present.

1. **True – incorrect.** The opening meeting is a short introduction to the audit process, and should not be extended by interviewing the management team.

2. **False – correct.**

61. During site visits, all the audit team must carry out site visits in one group.

1. **True – incorrect.**

2. **False – correct.** This may be the case for orientation site visits, but not for other types of site visits.

62. It is best to prepare a list of questions that each auditor should ask all interviewees.

1. **True – incorrect.** The questions should be specific to the interviewee and the information that needs to be gathered from the interview.

2. **False – correct.**

63. Audit requests for evidence could include:

1. **Photographs, emails, and internal reports – incorrect.**

2. **Documented procedures, work instructions, and copies of action plans – incorrect.**

3. **Previous audit reports – incorrect.**

4. **Records, certificates, and legal permits – incorrect.**

5. **All the above – correct.**

64. The debriefing sessions are an opportunity to:

1. **Ask any additional questions that were not already answered during the day – incorrect.** They should not be used to ask more questions.

2. **Give the auditee time to return any audit evidence requests – incorrect.** Although they may bring evidence to the meeting, the meeting should not focus on this.

3. **Managing the audit process, plan, and activities to make sure audit objectives can be achieved – correct.**

65. When a conflict occurs between the auditor and auditee and you are not competent in the subject matter, you should not be involved, and it should be left to the competent auditor to decide the outcome.

1. True – incorrect. Although you should not override your auditor for the sake of preventing conflicts, you need to act to resolve the cause of the conflict, or identify specifically what is in conflict and record it.

2. False – correct. You are responsible for managing conflicts, regardless of the subject matter.

66. Opening and closing meetings are an important part of the audit activities. Ideally, the management team should be invited to attend both meetings, but for shorter-duration audits, they should at least be invited to the closing meeting.

1. True – correct. You want the management team to hear the audit conclusions that you will present at the closing meeting.

2. False – incorrect.

67. The debriefing sessions should be used to discuss the audit progress with the audit client, and not to discuss audit findings between auditors.

1. True – correct. The debrief is held with the audit client to share information, and to check progress against the audit plan. It is not the time for auditors to discuss their audit findings with each other. This should be done during audit team meetings.

2. False – incorrect.

68. Conflicts between auditor and auditee should:

1. Be left to the auditor to sort out – incorrect. It is the lead auditor who takes responsibility for the behaviour of the audit team.

2. Be left to happen because they are part of a normal audit – incorrect. Although debate and challenge are healthy interactions for any audit, conflicts and arguments will negatively impact the audit.

3. Result in the auditor being dismissed from the audit team – incorrect. This action would be inappropriate unless the auditor behaved exceptionally badly (for example, becomes violent or abusive). In most cases, if the Lead Auditor takes actions, the conflicts can be resolved.

4. Be handled by the Lead Auditor with action taken to resolve the argument, or if agreement cannot be reached, to note the disagreement correctly – correct. This is the most appropriate action for the Lead Auditor to take.

Module 12 - Managing your audit team

69. Good audit team leadership ensures that:

1. Audit objectives are met – incorrect.
2. Audit team are aware of what, where, when, and how they will be part of the audit team – incorrect.
3. The audit plan provides a framework that has structure, but allows auditors the freedom to apply their own professional judgement – incorrect.
4. All of the above and more – correct. Good audit team leadership has many facets.

70. The audit team must decide on the audit scope and criteria during the pre-audit communications.

1. True – incorrect. The audit scope and criteria are decided as part of the audit program set by the certification body, and should not be changed by the audit team, unless done so in agreement with the certification body.
2. False – correct.

71. Managing audit progress includes both managing the information from the audit, and the time spent on different activities.

1. True – correct. Managing the flow of the audit information is critical to achieve the audit objectives.
2. False – incorrect.

72. Attendees of the audit team meetings must include:

1. The audit client representative and all of the audit team – incorrect. Although depending on your relationship with them, you may choose to invite them.
2. Local management and the audit team – incorrect.
3. The audit team – correct. The team meeting is for the audit team to manage their activities.
4. Interviewees, local management, and the audit team – incorrect.

73. Audit findings should be dismissed if the audit client does not agree with them.

1. True – incorrect. You should aim to ensure that the audit client has the opportunity to provide evidence of conformance, but if this is not adequate, the audit team and the Lead Auditor make the decision as to whether the audit finding is valid. If the audit client still disagrees, this should be recorded.
2. False – correct.

74. Auditors must make hard copies of the records they review as evidence of their audit trails.

1. True – incorrect. They need to maintain records that help support their audit findings, but not all the records they review, and they do not have to be hard copies.

2. False – correct.

75. Which of the following can be changed by the Lead Auditor without agreement from the certification body?

1. Audit plan – correct. You can make changes to this locally, in discussion with the audit team and audit client.

2. Audit scope – incorrect.

3. Audit criteria – incorrect.

4. Audit objectives – incorrect

76. Which statement is true?

1. Lead Auditors must, at a minimum, meet all the same competency requirements as every auditor on the audit team – incorrect. Auditors may have competencies in different management system standards, or have technical competencies that the Lead Auditor does not have.

2. Lead auditors must, at a minimum, meet the competency requirements of ISO 17021-1 – incorrect. ISO 17021-1 contains some competency requirements, but not all of them.

3. Lead auditors must, at a minimum, meet the competency requirements defined by the certification body – correct. The certification body needs to define competency requirements for Lead Auditors. ISO 17021-1 requires the certification body to put competency processes in place to meet Annex 2A.

77. Who is responsible for writing the audit plan?

1. Lead Auditor – correct. This is the key responsibility for the Lead Auditor, even if the audit client has firm ideas about when you should go, who you should meet, etc. The audit plan should be written so that you can best audit the organization to meet the audit objectives.

2. Audit client – incorrect.

3. Certification body – incorrect.

78. If one member of your audit team falls ill during the audit and is unable to participate in any more work, you should:

1. Cancel the audit immediately – incorrect. This may be the action you take after all, but not until looking at other options.

2. Carry on as planned, but just without the work done by this auditor – incorrect. Again, this might be the action you take, but not before looking at other options.

3. See if you can make changes to the audit plan in agreement with the audit client, and if not, contact the certification body – correct. There may be possible options to work around the situation first, without affecting the audit objectives, scope, or criteria, by making changes to the audit plan. If not,

then you must inform the certification body of the situation to agree with them and the audit client regarding what action should be taken.

4. Contact the certification body and delay the audit until a new auditor can be sent as a replacement – incorrect. This may be the action you agree on eventually, after looking at other options.

79. Photographic copies of documents are not official audit documents and cannot be used to replace hard paper copies.

1. True – incorrect.

2. False – correct. Photographs and photographic copies of documents are good ways to manage audit records, and can be a useful way to help retain copies of documents.

80. You're a good Lead Auditor when:

1. The audit team worked well together, working to each auditor's strengths – incorrect.

2. The audit process was kept on track effectively, but responded to changes when necessary – incorrect.

3. There was positive interaction with the audit client, with a fair, balanced, and honest audit conclusion – incorrect.

4. All of the above – correct. All of the above are examples of what a good lead auditor should be seeking to achieve.

Module 13 - Completing a successful audit

81. Audit findings are:

1. A record of non-conformity with audit criteria – incorrect. Audit findings can be both examples of conformity or non-conformity with audit criteria.

2. Opportunities for improvement that were found during the audit – incorrect. Audit findings are also an evaluation, not just an observation.

3. Evaluation of the audit evidence against the audit criteria – correct.

82. The audit conclusion is made by selecting the most significant non-conformities.

1. True – incorrect. The audit conclusion is an evaluation of all the non-conformities against the audit objectives.

2. False – correct.

83. A closing presentation should be:

1. No longer than 10 minutes to present the audit conclusion – incorrect. This is not a closing meeting, but a brief to management on the audit conclusions, and 10 minutes does not give you time to explain the understanding that went into the audit conclusions.

2. As long as it takes to explain all the detailed information gathered during the audit – incorrect. You do not need to present all the detailed information gathered; rather, use the audit evidence and any non-conformity to explain your audit conclusions.

3. Approximately 30 minutes to 1 hour to give time to present the audit process, the audit evidence, any non-conformity, and audit conclusions – correct. This is about the right amount of time, depending on the audit.

84. The closing meeting should only include the audit conclusions, given that this is the only thing the audit client is really interested in.

1. True – incorrect. The contents of the closing meeting must include all of the required components for a certification audit.

2. False – correct.

85. If the audit client does not agree with the audit conclusions, the Lead Auditor should:

1. Argue their point until the audit client finally understands – incorrect. This generally won't help your audit or help your audit client to accept your audit conclusions.

2. Explain their audit conclusions using facts and examples of evidence, and then record any objections in the audit report – correct. This is the right course of action to take.

3. Contact the certification body to confirm their audit conclusions – incorrect. Although there is nothing wrong with discussing the issue with the certification body if you wish, you still need to explain the audit conclusions and record any objections.

4. Get the auditor team to reach a consensus decision so they are not making the decision without the support of the audit team – incorrect. Although you want to include the audit team's views and opinions, the Lead Auditor is responsible for making the decisions.

86. Which of the following is an appropriate audit conclusion for a certification audit report?

1. The audit has identified four areas of non-conformity – incorrect. This tells the audit client how many non-conformities, but not what the conclusions of the audit are.

2. Based on the status of conformance of the organization's management system to the ISO 14001:2015 standard, the organization is recommended for certification – correct.

3. The organization's Management Review procedures do not meet the requirements of the ISO 14001:2015 management system standard – incorrect. Audit conclusions for a certification audit should be a statement of the Lead Auditor's decision to recommend the organization for certification.

87. The purpose of the corrections and corrective action is to demonstrate how the organization will address non-conformities and their root causes, including timescales and responsibilities.

1. True – correct. This is the purpose of corrections and corrective action.

2. False – incorrect.

88. For certification audits, the auditee needs to approve the audit report before it is finalized.

1. True – incorrect. For certification audits, the auditee does not need to approve the report.

2. False – correct.

89. The difference between a major non-conformity and a minor non-conformity is the severity of the consequences to the business, for example compliance implications or cost.

1. True – incorrect.

2. False – correct. The significance is based on whether the process is achieving the intended outcomes, not on the severity of any potential consequences to the business.

90. The audit report should include recommendations on how to fix the non-conformities, so that the organization knows how to fix the issue.

1. True – incorrect.

2. False – correct. The auditor should not make recommendations. The audit client needs to identify root causes for any non-conformities and identify their own corrections and corrective actions.

91. The closing meeting can be skipped if the audit has run out of time.

1. True – incorrect.

2. False – correct. The closing meeting is a mandatory part of a certification audit, and all the required content must be covered.

